開発意図と静的・動的解析を照合する Android アプリ通信の確認支援

システムの設計と、自作参照素材による規則の動作確認

研究室・卒業論文発表用 | 著者名・所属を記入

主評価

3 条件 × 3 反復
計 9 端末試行

補助結果

従来の 29 試行
公開アプリ 1 本を含む

説明の根拠

意図・操作・通信
証拠 ID と原本参照

最初に結論： 3 種類の結果を区別できた

許可した入力先

整合
3 試行 / 3 試行

許可外の固定先

不一致候補
3 試行 / 3 試行

対象要求が未観測

判定不能
3 試行 / 3 試行

結論の範囲：自作参照素材で、設計した規則が期待どおり動作した。

背景：自分のアプリの通信を把握したい

開発時の想定

必要な API ・入力先
使う権限と依存
通信する操作条件

実装に含まれるもの

ライブラリの宣言
組み立てられる URL
操作や状態で変わる処理

確認したいこと

宣言と合うか
条件外の候補はあるか
何がまだ分からないか

AI 支援開発への活用は動機。 AI 生成アプリ一般の危険性は評価していない。

研究目的：事前の意図を判断の基準にする

入力

事前の意図 JSON
APK
操作シナリオ

証拠を得る

静的な宣言・候補
指定操作中の通信
取得・時刻の条件

意図と照合

許可・禁止・未指定
帰属・方式・区間
不足情報の確認

説明する

判定と観測状態
静的・動的の対応
原本への参照

意図は観測結果から逆算せず、解析前に保存する。

確認範囲：宛先・宣言・観測条件を扱う

確認対象	得られる根拠	この証拠だけでは確定しないこと
通信先・方式	UID 付き通信、 Host 、ポート	暗号化本文・送信データの妥当性
権限	Manifest の宣言	実際の権限使用・個人情報取得
SDK 候補	登録特徴との一致	SDK の初期化・送信主体
操作との関係	シナリオと補正時刻	実行経路・因果・全操作の網羅

出力は自己確認のための候補と不足。アプリ全体の安全性保証にはしない。

出典：改訂草稿 第 1 章・第 9 章

研究課題：候補提示・保留・根拠追跡

RQ1　候補提示	許可条件外の要求・権限宣言を、根拠付きで示せるか。
RQ2　区別と保留	許可入力先への要求と対象未観測を、異なる出力にできるか。
RQ3　根拠の追跡	意図・操作・原本へ戻り、照合結果と対応表を再現できるか。

出典：改訂草稿 §6.1 ・ §9.1

システム構成：照合と差分説明を分ける

事前意図・ APK ・シナリオ → 入力検証と意図スナップショット

静的解析

Manifest ・ DEX ・リソースの宣言と候補

動的取得

ADB ・ PCAPdroid ・操作と前後対照

正規化・帰属・時刻補正・証拠索引

主処理：意図との照合

根拠：静的・動的の対応と差分

出力： JSON / CSV / HTML ＋ 指摘 → 証拠 ID → 原本

出典：改訂草稿 図 1 ・第 4 章

意図 JSON： 何を許可するかを先に宣言する

```
network:
  mode: allowlist_or_recorded_inputs
  allowed_destinations: []
  recorded_input_protocols: [http, https]
permissions: INTERNET のみ
sdk: deny_all
cleartext_policy: allow
```

3 つの意味を区別

許可集合／明示禁止／未指定

保存時点も証拠

解析前の内容と読み込み時刻を記録

記録された入力先の例外は、帰属・操作・方式・時刻の条件がそろう場合だけ。

出典： intent-recorded-input-v1.1.json ・改訂草稿 §5.2

結果は「判定」と「観測状態」を分けて読む

verdict	読み方	併記する情報
整合	今回比較できた明示条件を満たす	観測： HTTP / 接続試行 / 未観測 等
不一致候補	比較可能な記録が明示条件に反する	帰属：対象 / 別 UID / 不明
要確認	意図未指定・静的候補等の確認対象	本文：なし / メタデータ / 平文
判定不能	帰属・観測・方式などの根拠が不足	取得品質： completed / partial 等

単一の危険度スコアにまとめず、何が分かっているかを残す。

出典：改訂草稿 §3.3 ・ §3.4 ・表「判定と観測情報の軸」

静的解析：宣言と候補を所在付きで抽出する

Manifest

権限・コンポーネント
通信セキュリティ設定
宣言の所在

DEX ・リソース

URL 文字列・クラス特徴
登録 API の命令参照
複数 DEX を走査

解析の境界

限定的な引数追跡
接頭辞等による SDK 候補
実行・送信は別に確認

自作の固定先素材は補助メソッドで宛先を組み立てる構成。抽出器の一般精度にはしない。

出典：改訂草稿 §4.3 ・ §5.5

動的解析：取得の前後も対照要求で確認する

① 前対照

開始・補助 UID
HTTP 応答を確認

② 起動

対象を起動
5 秒観測

③ 入力

登録 URI を開く
30 秒観測

④ 後対照

停止と記録保存
対象素材を停止

主評価 9 試行 × 前後 2 要求 = 18 対照要求を原本で照合

元 APK を使い、アプリデータを保持。本文復号・再署名を取得の必須条件にしない。

出典：改訂草稿 §4.4 ・ §7.1

帰属・プロトコル・時刻を正規化する

アプリ帰属	インストール UID と記録 UID を照合。不明は unknown として残す。
観測段階	接続試行・ TCP ・ TLS ・ HTTP を区別。ポートだけで昇格させない。
操作と時計	フローの区間と時計の幅を、成功した登録操作の区間へ照合する。

「動的のみ」でも、意図との関係は異なる

静的・動的の関係	意図と照合すると	今回の例
静的候補なし ＋ 対象要求あり	許可入力先なら整合	入力先要求 3 試行
静的候補なし ＋ 対象要求あり	許可外ポートなら不一致候補	固定先要求 3 試行
対象要求を観測できない	観測不足として判定不能	遅延予定 3 試行

静的・動的の対応表は根拠表示。判断の基準は事前の意図。

出典：改訂草稿 §9.2 ・ §9.3

評価設計： 3 条件を各 3 回、事前に保存する

解析前に固定

意図 JSON
APK ・コードの hash
9 シナリオと順序

実行する条件

入力先要求
許可外の固定先要求
75 秒後の要求予定

評価の単位

各条件 3 回＝ 9 試行
同一 AVD の反復
同じ開発側の参照素材

期待出力は素材仕様と規則から定まる。未知アプリの検出精度を測る標本ではない。

出典： seed-plan.json ・改訂草稿 第 6 章・第 7 章

実験環境と、誰が何を実施したか

項目	固定した環境・役割
ホスト	macOS 27.2 arm64 / Python 3.11.9 / ADB 35.0.1
端末	API35 ・ arm64-v8a / Pixel_8_Edited_API_35
収集器	PCAPdroid 2.0.2 / CaptureCtrl / UID 拡張 PCAP
著者本人	コマンド実行、 Android の同意確認、操作状況の記録
生成 AI 支援	APK ・ランナー作成、オフライン再解析、集計、執筆

単一環境での動作確認。実装支援と、本人による端末実行を区別して開示する。

出典：改訂草稿 付録 A ・ roles.json

3 素材の違い：宛先と待機時間を制御した

素材	実装仕様	期待する照合の範囲
入力先	登録 URI へ要求： 18762 / 18763	根拠条件がそろえば整合
固定先	同じホストの 18761 へ要求	許可外ポートの不一致候補
遅延予定	要求は 75 秒後。窓は 30 秒	対象未観測として保留

同一ホストでポートを変えた参照条件。外部広告事業者や個人情報送信の検出ではない。

出典：自作参照ソース・改訂草稿 §7.2

主結果：期待した 3 出力を 9 試行で確認した

条件（各 3 試行）	対象要求	主な verdict	observation
入力先	各 1 件	整合： 3/3	HTTP 観測
許可外固定先	各 1 件	不一致候補： 3/3	HTTP 観測
遅延予定	0 件	判定不能： 3/3	対象未観測

自作素材の規則動作確認である。 3/3 を「一般精度 100% 」に置き換えない。

出典： trial-results.csv ・改訂草稿 表 7

具体例：入力先 18762 に対し、 18761 へ要求した

事前の意図と操作

記録した入力先だけ許可
入力： 10.0.2.2:18762
固定許可先は空

保持した観測

対象 UID の HTTP 要求
宛先： 10.0.2.2:18761
GET は PCAP の 18 番

出力された指摘

F00006 / C02
不一致候補
HTTP 観測・対象帰属

同じホストでも、許可条件にないポートは別の宛先条件として扱う。

指摘から、原本のどこを見ればよいか分かる

指摘

F00006
C02 不一致候補

索引

証拠 ID
所在・ SHA-256

原本

PCAP 15 ～ 24 番
操作・意図記録

補助点検

サーバー受信と候補対応を確認

GET ヘッダ： 18 番 ／ 対象フロー： capture-1-flow-4

原本の所在確認と、サーバーの候補対応を分けて記録する。

出典： evidence/index.json ・改訂草稿 図 2

方式比較：今回の通信判定は動的のみと一致した

方式	入力先 3 試行	固定先 3 試行	遅延 3 試行
静的のみ	実通信は対象外	実通信は対象外	実通信は対象外
動的のみ	整合	不一致候補	判定不能
併用	整合	不一致候補	判定不能

27 出力は同じ記録の再解析。新しい 27 端末試行や、精度向上の証拠ではない。

出典： component-analysis.csv ・改訂草稿 §7.3

従来の 29 試行は、取得と差分説明の補助結果

補助群	試行数	対象あり	不明候補あり
制御 CSV 群	19	14	4
自動 HTTP	1	1	0
公開アプリ起動	1	0	0
RSS 操作	4	4	0
URI 切替	4	4	1

補助 29 ＋主評価 9 ＝ 38 端末試行。意図の時点と評価目的を混ぜて精度計算しない。

出典： final29-trials.csv ・改訂草稿 付録 B

不確実性：主評価の未観測と、補助群の帰属不明

主評価 9 試行

帰属不明は 0
未観測 3 を判定不能へ
全取得品質は partial

補助群の UDP

帰属不明 4 単位
保持・削除等の事後比較
主評価へ数えない

停止統計との違い

delayed-001： 39 → 40
fixed-003： 38 → 39
各 1 パケット差を保存

対象未観測・帰属不明・取得不足は別の状態。無通信や対象違反へ補完しない。

出典：改訂草稿 §9.4 ・ capture-quality-detail.json

関連研究：構成要素を継承し、対象を限定する

先行研究の系統	確認した対象	本研究の焦点
PoliCheck / PurPliance PoliGraph	ポリシーとデータ利用・意味表現	開発者が事前に宣言した構造化条件
Agrigento	個人情報源変更・差分通信・非決定性	登録 URI と宛先の対応は補助確認
DroidBot / MobSF / 取得ツール	自動操作・静的動的解析・通信取得	既存手段で証拠を得て意図と照合

貢献の置き方：具体的な確認手順と実装、参照条件での動作確認。

結論と研究の区切り

設計した規則が、自作参照素材の条件で期待した照合出力を返すことを確認した。

実装したもの

事前意図との照合
静的・動的の根拠表示
原本への追跡

今回の制約

同じ開発側の素材
単一 AVD ・限定した操作
一般精度は未確立

残る確認

本人による説明・形式
独立確認 12 件は未実施
AI 利用を適切に開示

以降は補足資料。追加実験を通常の次工程として増やさない。

出典: 改訂草稿 第 10 章・レビュー対応記録

A01 ｜主評価 9 試行の全台帳

試行	入力ポート	観測ポート	主要出力	保存–停止
input-001	18762	18762	整合	0
fixed-001	18762	18761	不一致候補	0
delayed-001	18762	未観測	判定不能	1
input-002	18763	18763	整合	0
fixed-002	18763	18761	不一致候補	0
delayed-002	18763	未観測	判定不能	0
input-003	18762	18762	整合	0
fixed-003	18762	18761	不一致候補	1
delayed-003	18762	未観測	判定不能	0

各条件 3 反復。静的な位置権限素材はこの 9 試行に含めない。

出典：主評価 trial-results.csv

A02 ｜試行・フロー・再解析の単位を分ける

数字	単位	使い方
9	主評価の端末試行	3 条件 ×3 反復の規則動作確認
29	既存の補助端末試行	取得・帰属・差分の確認
38	全体の端末試行数	同じ事前計画の精度分母にしない
27	3 方式の再解析出力	新たな端末試行へ数えない
1	別の静的権限素材	権限宣言の確認

A03 ｜規則ごとの判定順序

① 前提	取得・帰属などの前提が不足 → 判定不能
② 意図	そのカテゴリが未指定 → 要確認
③ 比較可能性	ホスト・方式・時間などが不足 → 判定不能
④ 明示条件	満たせば整合、反すれば不一致候補

出典：改訂草稿 §3.3 ・ compare.py

A04 ｜記録入力先の許可に必要な条件

登録の根拠

意図で例外を明示
シナリオと UI 記録
ファイル hash を確認

通信との対応

対象 UID
同一ホスト・ポート
必要な観測プロトコル

時間の条件

フロー開始〜終了
時計の幅を加える
操作区間へ収まるか

リダイレクト先・任意画面の手入力・ SDK 起因を自動で許可／推定しない。

出典： intent_extensions.py ・改訂草稿 §5.2

A05 ｜ HTTP ・ TLS ・ UDP の読み取りの限界

観測	得られること	残る制約
HTTP ヘッダ	要求・ Host 等の明示情報	分割ヘッダ・全 TCP 再構成
TLS / SNI	見える範囲のホスト根拠	HTTPS 本文・ピンニング・ HTTP 意味
UDP	宛先・通信量・一部 UID	帰属欠落・アプリ内容の意味
ポート 443	宛先ポートの値	HTTPS / QUIC と自動断定しない

A06 ｜ AntennaPod： URI 切替 4 試行の補助事例

順序	入力ポート	観測ポート	GET / 応答	品質上の注記
A	59521	59521	43 番 / 200	保存 124 、停止 123
B	59522	59522	55 番 / 200	partial
B	59522	59522	53 番 / 200	UID 不明 UDP/443 が併存
A	59521	59521	39 番 / 200	partial

支持するのは登録入力先と要求先の対応。単一要因の因果・一般精度の証明ではない。

出典： diagnostic-ab-002 原本点検・改訂草稿 §8.3

A07 ｜権限宣言と SDK 候補をどう扱うか

静的な別素材

精密な位置情報の権限
許可集合の外の宣言
C04 で不一致候補

観測した事実の範囲

Manifest の宣言を確認
位置・通信 API は未使用
主評価 9 試行とは別

SDK 登録ルール

Firebase Analytics
Google Mobile Ads
Facebook App Events
Sentry Android

宣言・特徴一致と、実際に使用／送信した事実を分ける。

出典：静的参照素材・ sdk_rules.json ・改訂草稿 §7.3

A08 ｜口頭試問で説明したい 5 つの点

質問	今回の答え
自作素材で何が言える?	規則が既知の参照条件で期待どおり動作した範囲。
併用で精度は上がった?	今回の通信判定は動的のみと一致。
不明の保持はどこで確認?	帰属不明は補助群、対象未観測は主評価で分けて確認。
意図はどう決めた?	解析前に JSON で宣言し、内容と時点を保存。
遅延通信を検出した?	今回は窓外の予定を保留した。送信前に停止。

A09 ｜参考文献：ポリシー整合性の研究

PoliCheck — Andow et al., USENIX Security 2020

Actions Speak Louder than Words: Entity-Sensitive Privacy Policy and Data Flow Analysis with PoliCheck

PurPliance — Bui et al., ACM CCS 2021

Consistency Analysis of Data-Usage Purposes in Mobile Apps

PoliGraph — Cui et al., USENIX Security 2023

PoliGraph: Automated Privacy Policy Analysis using Knowledge Graphs

複数状態・未指定・根拠追跡には先行例がある。

出典：原論文の関連節を確認（2026-11-03 〜 06）

A10 ｜参考文献：自動操作と差分通信解析

DroidBot — Li et al., ICSE Companion 2017

DroidBot: A Lightweight UI-Guided Test Input Generator for Android
実行時の UI モデルを使う入力生成。自動操作そのものは既存技術。

Agrigento — Continella et al., NDSS 2017

Obfuscation-Resilient Privacy Leak Detection for Mobile Apps
Through Differential Analysis
個人情報源の変更、非決定性の抑制、差分通信を扱う。

本研究は同等の漏えい検出・記録再生・探索能力を実装したとはしない。

出典： DroidBot ・ Agrigento 本文の関連節を確認

A11 ｜公式実装資料と、確認できていない文献

公式資料	今回使った確認範囲
FlowDroid / LibScout	データフロー解析／プロファイルによるライブラリ検出
MobSF / PCAPdroid	静的・動的機能／ VPN 方式の取得・ UID 拡張
AntMonitor / Androguard	VPN 取得・検査／ APK ・ DEX 解析基盤
Android 15 固定ソース	平文設定と既定の CA 信頼の条件

ReCon ・ Haystack/Lumen： 本文未確認のまま。確認済みの研究として扱わない。

出典：固定版公式資料・文献確認記録

A12 ｜ AI 利用・独立確認・追加実験の扱い

実行と支援

端末実行：著者本人
コード・再解析・執筆：AI 支援
利用範囲を論文で開示

独立確認

12 件の資料は準備済み
実施済みは 0 件
空欄票と宣言を用意

追加の取得

新しい端末実験は 0
90 秒観測は任意の拡張
結果だけを理由に増やさない

発表時は、データの出どころ・本人の操作・言える範囲を自分の言葉で説明する。

出典： roles.json ・レビュー対応表・独立確認用資料